-8-O-887-:-7-<">

Техническое задание: Сервис управления профилями и заказами

Часть 3. Разграничение прав доступа (RBAC) и межмодульное взаимодействие

3.1. Ролевая модель и матрицы прав (TR-SEC-01)

В системе предусмотрено 4 типа ролей пользователей: `GUEST`, `CUSTOMER`, `MANAGER`, `ADMIN`.

Эндпоинт / Действие	GUEST	CUSTOMER	MANAGER	ADMIN
`POST /api/v1/auth/register`	✓	✓	✓	✓
`POST /api/v1/orders/create`	✗	✓	✓	✓
`POST /api/v1/orders/apply-discount`	✗	✗	✓	✓

- **Правило доступа к скидкам:** Применение ручных скидок (`apply-discount`) разрешено **только** пользователям с ролями `MANAGER` или `ADMIN`.
- **Обработка нарушений:** Если пользователь с ролью

`CUSTOMER` или `GUEST` пытается вызвать эндпоинт скидок, система обязана перехватить запрос на уровне Middleware/Guard и вернуть HTTP-код `403 Forbidden` с сообщением: `"Access denied: insufficient privileges"`

3.2. Архитектура межмодульных вызовов и атомарность (TR-SEC-02)

- **Связь заказов и склада:** При вызове функции создания или модификации заказа в модуле `orders.py` разработчик **обязан** явно вызывать внешнюю функцию проверки и резервирования из складского модуля: `app.services.inventory.reserve_stock(item_id, quantity)`.
- **Запрет прямой модификации:** Прямое уменьшение остатков на складе через запрос к базе данных в обход сервиса `inventory.py` является грубым архитектурным нарушением